

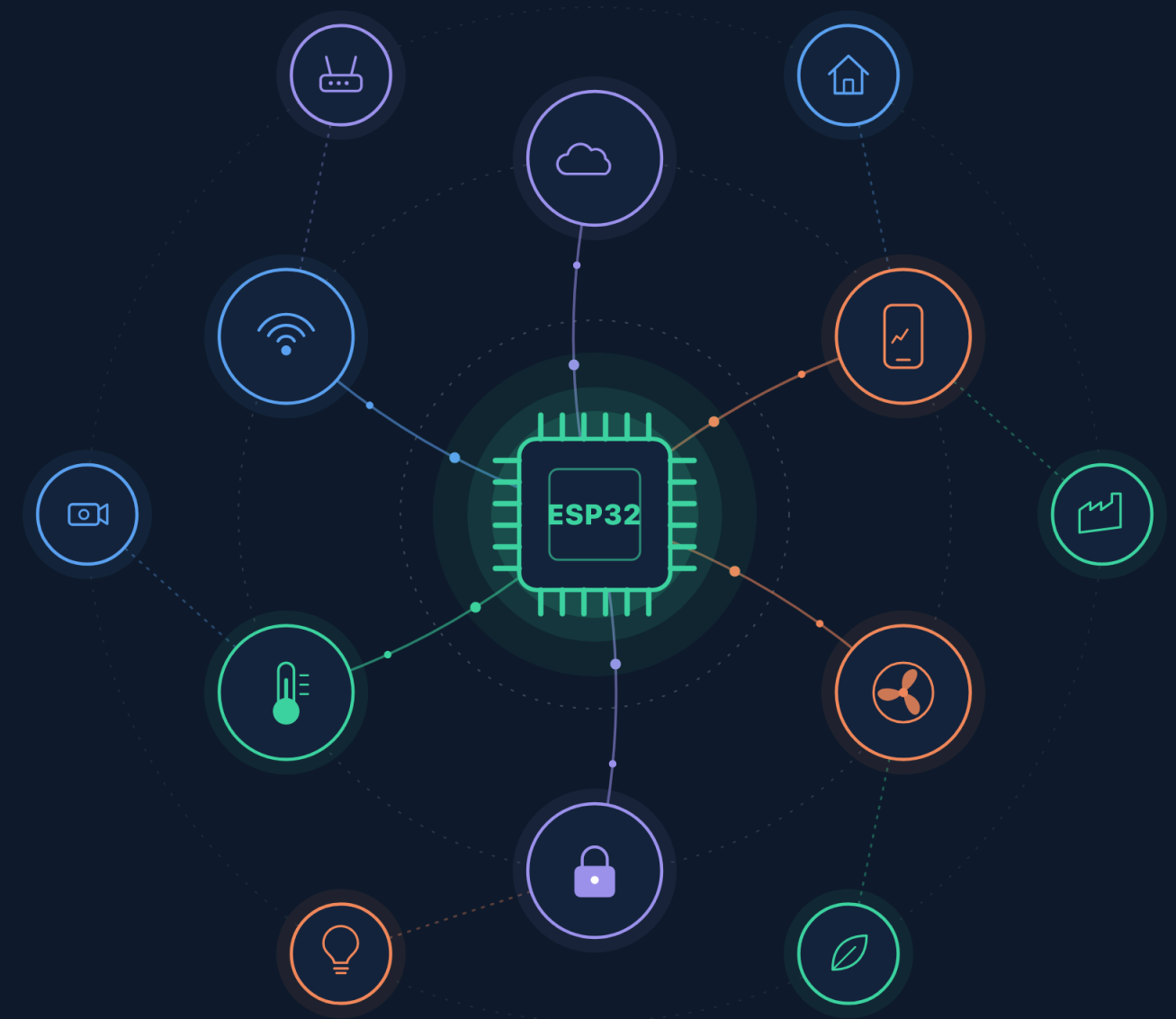
MODULE 7 • 45 MINUTES

IoT Security and Best Practices

How IoT devices get attacked, the proven defences, and the standards and laws that now apply.

Mehdi Lotfinejad

Introduction to the Internet of Things



THE ROAD AHEAD

Eight modules, one smart device

PART 1 — DEVICES AND DATA

01

What is IoT?

Lecture

02

How it's built

Lecture

03

Sensors and actuators

Labs 1–2

04

Getting online

Lab 3

PART 2 — CLOUD, AUTOMATION AND SECURITY

05

Cloud and dashboards

Lab 4

06

Automation

Lab 5

07

Security

You are here

08

Real world + capstone

Lab 6

BY THE END OF THIS MODULE

You will be able to...

-
- 01 **Explain** why IoT is a target, and its most common weaknesses
 - 02 **Explain** authentication, authorisation and encryption
 - 03 **Describe** what makes a firmware update secure
 - 04 **Name** the main standards and laws, including Malaysia's
 - 05 **Spot** common security mistakes in code and settings
-

WHERE WE ARE

The shortcuts we took in the labs



Public broker

Lab 3: a public MQTT broker, with no password and no encryption.



Plain HTTP

Lab 4: data sent over plain HTTP, with the API key in the code.



Wi-Fi in code

In all the labs, the Wi-Fi details are written into the code.

Fine for simulated temperature readings. In a real product, each one is a **security hole**.

Part A

Why IoT is a target

What attackers look for, and what we need to protect.

Why IoT devices are attractive targets



So many

Billions of devices,
and many are
identical.



Rarely updated

A weakness found in
year one is still
there in year five.



Rushed design

Weak passwords,
old software, and no
way to fix them.



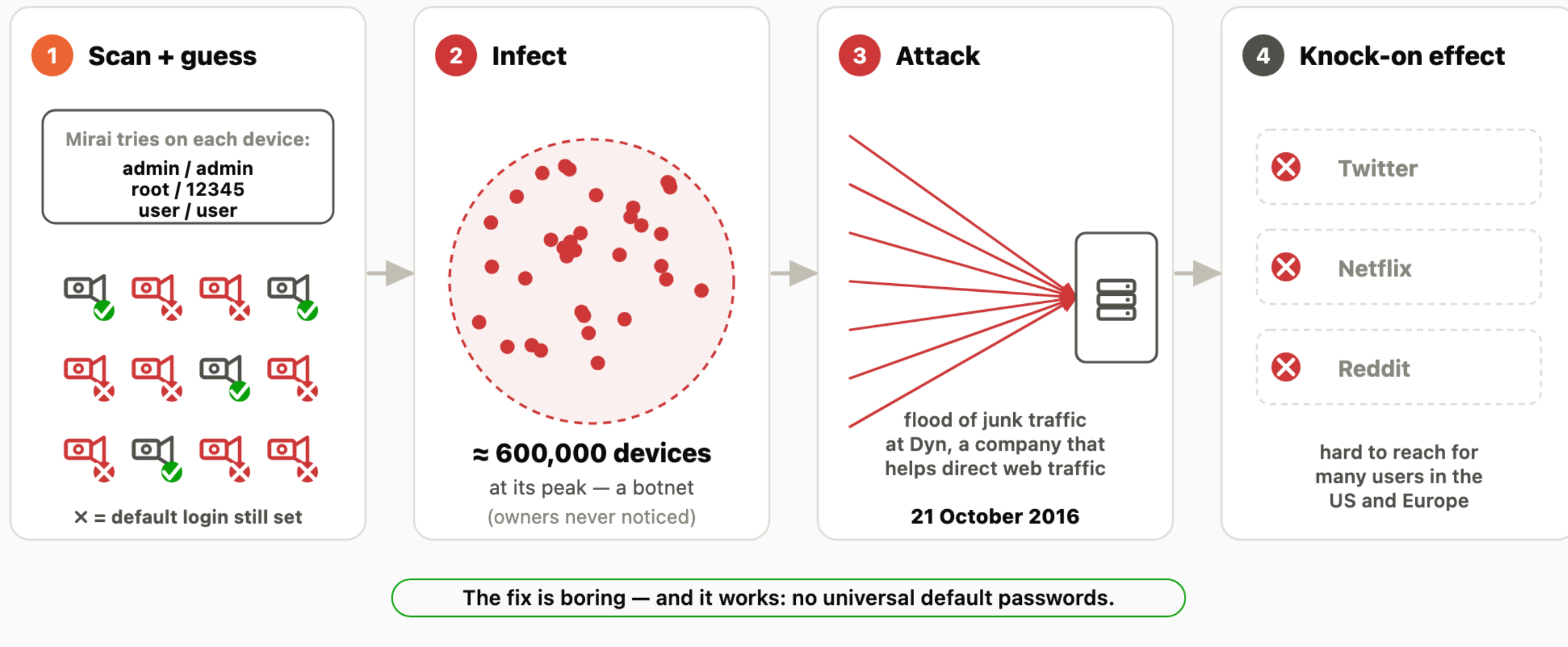
Physical world

An attack can
unlock a door, or
switch off a freezer.

The Mirai botnet

How default passwords built the Mirai botnet (2016)

No clever hacking — just a short list of factory logins, tried on every device it could find.



WHAT ARE WE PROTECTING?

The CIA triad

Goal	Means	When it goes wrong
Confidentiality	Only the right people can see the data	A stranger watches your baby-monitor camera
Integrity	Data can't be secretly changed	A fake sensor reading shuts down a factory
Availability	It keeps working when needed	A smart lock won't open: its cloud is down

In IoT there is often a fourth goal: **safety**. A security failure can put people in danger.

The attack surface



Devices

Default passwords, open ports,
physical tampering



Connectivity

Eavesdropping and fake messages



Edge

Local tampering and gateways that
are never patched



Cloud platform

Weak access control and stolen
API keys



Application

Web dashboards and phone apps
that are insecure



People

Phishing and unchanged settings

THE MOST COMMON WEAKNESSES

The OWASP IoT Top 10

#	Weakness	#	Weakness
1	Weak, guessable or hardcoded passwords	6	Insufficient privacy protection
2	Insecure network services	7	Insecure data transfer and storage
3	Insecure ecosystem interfaces	8	Lack of device management
4	Lack of secure update mechanism	9	Insecure default settings
5	Insecure or outdated components	10	Lack of physical hardening

Published in 2018 and still current. Most items are about **defaults** and **neglect**.

PAUSE AND CHECK

Think back to our lab shortcuts: a public broker, no encryption, and secrets in the code. Which OWASP items do they match?

Look at the Top 10 again. Talk to your neighbour for one minute.

Part B

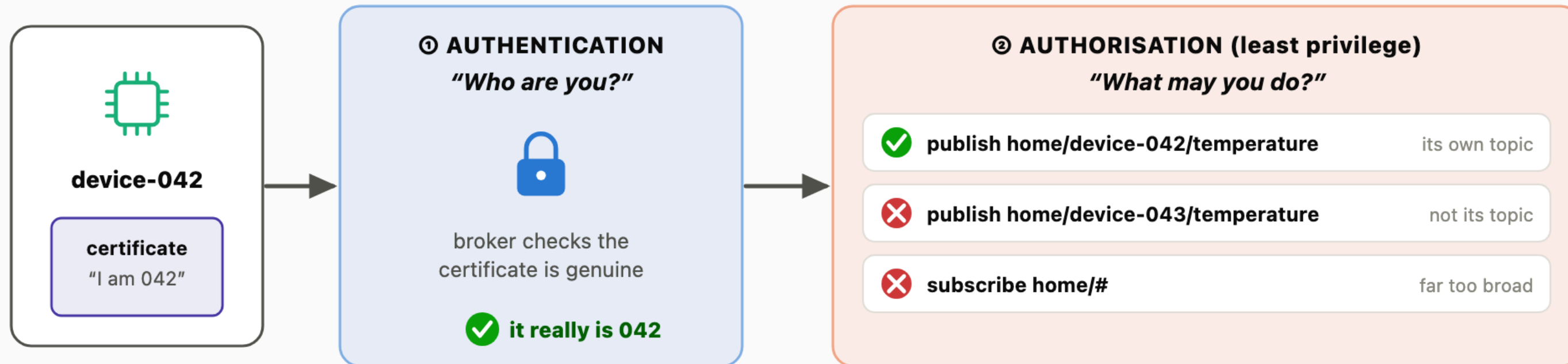
Four defences

Strong identity, encryption, secure updates, and secure by design.

Authentication and authorisation

Authentication vs authorisation

Two separate checks at the MQTT broker: who are you? — then — what are you allowed to do?



Everyday comparison: a hotel

● **Passport at check-in**
= authentication (who you are)

🔒 **Key card opens only YOUR room**
= authorisation (what you may do)

FROM WEAKEST TO STRONGEST

How devices prove who they are

Method	How it works	Strength
No authentication	Anyone can connect, like the Lab 3 broker	None — learning only
Shared password	Every device uses the same password	Weak: steal one, get all
Unique key per device	Each device has its own secret	Better: one leak, one device
Certificate per device	A unique certificate and a secret key	Strongest: professional

With certificates and encryption, **both sides** check each other: *mutual authentication*.

Protect data in transit and at rest

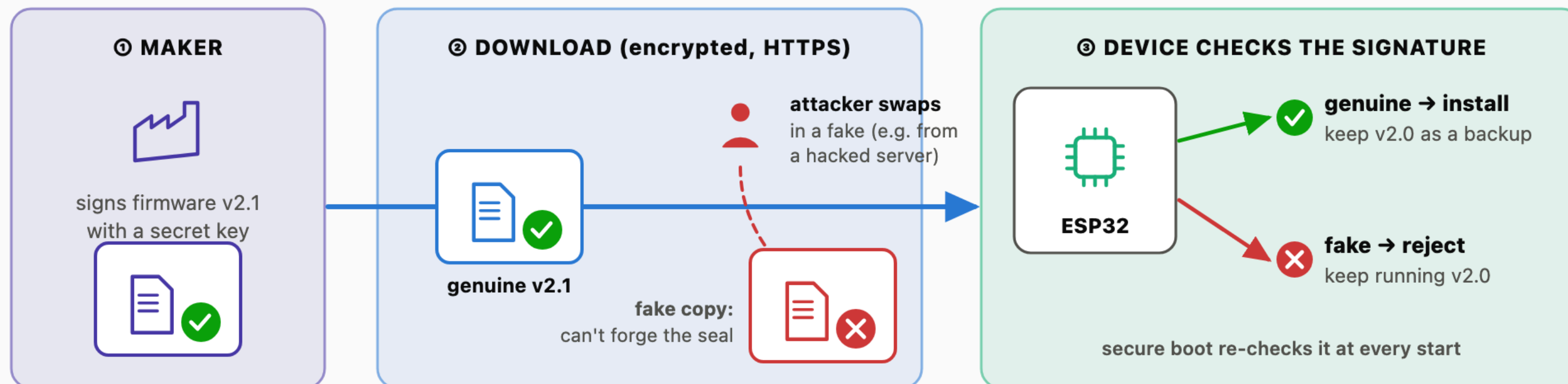
	Insecure	Secure
Web requests	http:// (port 80)	https:// (port 443)
MQTT	port 1883	port 8883, with TLS
Stored data	Plain text	Encrypted

Keep secrets out of code. And use **both** encryption and authentication: TLS checks the server’s certificate.

A secure firmware update

A secure firmware update, step by step

The device installs an update only if the maker's digital signature checks out.



Why each step matters

- Signing proves WHO made it and that nobody changed it.
- Encryption stops others reading or tampering with it on the way.
- Keeping the old version means a failed update never "bricks" the device.

DEFENCE 4

Secure by design



Minimise

Switch off every port and service you don't need.



Defence in depth

If one layer fails, another still holds.



Collect less

Data you never collect can never be leaked.



Whole life

Plan how it's set up, updated and retired.



Easy to report

Let researchers report weaknesses to you.

Part C

Standards and laws

From “nice to have” to “required by law”.

Four standards to know

Name	From	What it is
OWASP IoT Top 10	OWASP, a non-profit	The ten most common weaknesses: a checklist
ETSI EN 303 645	The European standards body	Consumer IoT baseline; no default passwords
NIST IR 8259	The US standards agency	Guidance for device makers; Rev. 1 in April 2026
IEC 62443	International Electrotechnical Commission	For industrial systems: zones and security levels

IoT security laws



UK PSTI Act

Since April 2024: bans guessable default passwords.



EU CRA

Full rules from 11 December 2027.



US Cyber Trust

A voluntary label, still rolling out.



Cyber Security Act

Act 854, for critical sectors; overseen by NACSA.



PDPA (2024)

Personal data breaches reported within 72 hours.



MCMC codes

Technical codes on IoT security.

A summary, not legal advice. For a real product, check the latest official sources.

COMMON MISCONCEPTIONS

Four ideas that trip people up

✗ Myth *My device is too small and boring to be attacked.*

✓ Fact Tools like Mirai scan the whole internet for any weak device.

✗ Myth *Hiding the Wi-Fi network name makes it secure.*

✓ Fact Hidden networks are easy to find. Use passwords and encryption.

✗ Myth *Encryption solves everything.*

✓ Fact It doesn't stop weak passwords, fake updates or stolen keys.

✗ Myth *Once it's secure, it stays secure.*

✓ Fact New weaknesses appear all the time. Devices need updates.

REAL-WORLD EXAMPLE

Securing our smart room monitor

In the labs	In a real product
Public MQTT broker, anyone can join	Private broker, or a platform like AWS IoT Core
No authentication	A unique certificate for each device
Port 1883, unencrypted	Port 8883 with TLS encryption
Any client can read <code>iot-workshop/#</code>	Each device may only use its own topics
Plain HTTP to ThingSpeak	HTTPS
Wi-Fi password and API key in the code	Secrets stored separately, never shared
No way to update the device	Signed OTA updates, stated support period
—	A published way to report security problems

Spot the vulnerability

- 1 Form groups of 2–3. Each group takes 2–3 of the five snippets.
- 2 For each snippet, ask: **what's wrong?**
- 3 Then ask: **what's the realistic worst case?**
- 4 And: **how would you fix it?** Every fix is in this module.
- 5 Share your answers: one sentence each.

DEBRIEF

Five snippets, five fixes



Wi-Fi on GitHub

Store secrets in a separate file that's never shared.



admin / admin

Force a new, unique password at first setup.



Plain HTTP

Use HTTPS, and MQTT on 8883 with TLS.



One lock topic

Give each lock its own identity and its own topic.



Unsigned update

Sign it, send it over HTTPS, and check the signature.

Every one of these is on the **OWASP IoT Top 10** checklist.

KEY TAKEAWAYS

What to remember

- ✓ Mirai showed the damage **default passwords** alone can do
- ✓ Protect **confidentiality, integrity, availability** — and **safety**
- ✓ **Authentication** proves who; **authorisation** limits what
- ✓ Encrypt **in transit** and **at rest**; keep **secrets out of code**
- ✓ Updates must be **signed, encrypted** and able to **fall back**

Quick quiz

Q1 Why did the Mirai botnet take over so many devices?

Q2 Authentication or authorisation? Give an IoT example of each.

Q3 What is data in transit and data at rest? How do you protect each?

Q4 A smart camera recognises residents' faces. Which Malaysian law applies?

UP NEXT • MODULE 8

Real-World IoT Applications and Project Showcase

We pull the whole day together: complete systems from real industries, from prototype to deployment, and your capstone in Lab 6.



Mehdi Lotfinejad

Book, labs and slides: github.com/datatweets/intro-to-iot-workshop